

CYBERSECURITY

LAB 11

1. Introduction

Enumerating target is a process that is used to find and collect information about ports, operating systems, and services available on the target machines. This process is usually done after we have discovered that the target machines are available. In penetration testing practice, this task is conducted at the time of the discovery process. The goal of performing the enumeration process is to collect information about the services available on the target systems.

From the attacker's point of view, the same process is used to find weaknesses in the attacked systems that will allow to bypass the applied security measures. In modern systems, attacks that allow to break through security are expensive, both in terms of time and computing resources, so network reconnaissance is an important step in preparing the final attack. The development of network infrastructure and devices communicating through network protocols means that especially in corporate networks there are many elements that can be used as furs to take over data, accounts or control on the network.

Nmap (Network Mapper) is a security scanner used to discover hosts and services on a computer network, thus creating a "map" of the network. To accomplish its goal, Nmap sends specially crafted packets to the target host and then analyzes the responses. Unlike many simple port scanners that just send packets at some predefined constant rate, Nmap accounts for the network conditions (latency fluctuations, network congestion, the target interference with the scan) during the run.

Please keep in mind some legal restrictions on the use of Nmap. In some countries it is prohibited by law to use tools that can be used to carry out or facilitate hacking attacks. In this case, using Nmap even to find devices on the network you are using (e.g. for testing the API of services on them) will be considered a violation of the law. At the same time, in other countries these issues are not regulated by law in any way, and sometimes using tools such as Nmap leads to litigation.

The choice of scanning parameters is also an important issue. Depending on the options used, the process may be practically undetectable, but it will last for weeks or you will get the results in seconds or minutes, but the traffic generated during the scan will be easy to notice.

Besides being used as a port scanner, Nmap has several other capabilities as follows:

- Host discovery
- Service/version detection
- Operating system detection
- Network traceroute

There are six port states that are recognized by Nmap as follows:

- **Open:** This means that there is an application accepting a TCP connection, UDP datagram, or SCTP association.
- **Closed:** This means that although the port is accessible, there is no application listening on the port.
- **Filtered:** This means that Nmap can't determine whether the port is open or not because there is a packet-filtering device blocking the probe to reach the target.

LAB 11

- **Unfiltered:** This means that the port is accessible, but Nmap cannot determine whether it is open or closed.
- **Open | Filtered:** This means that Nmap is unable to determine whether a port is open or filtered. This happens when a scan to open ports doesn't give a response. It can be achieved by setting the firewall to drop packets.
- **Closed | Filtered:** This means Nmap is unable to determine whether a port is closed or filtered.

In order to correctly interpret the results obtained as a result of the scan, it is necessary to remember the basic differences between connection protocols (e.g. TCP) and nonconnection protocols (e.g. UDP). As a result of the scan Nmap reports different responses depending on which connections the port is open to.

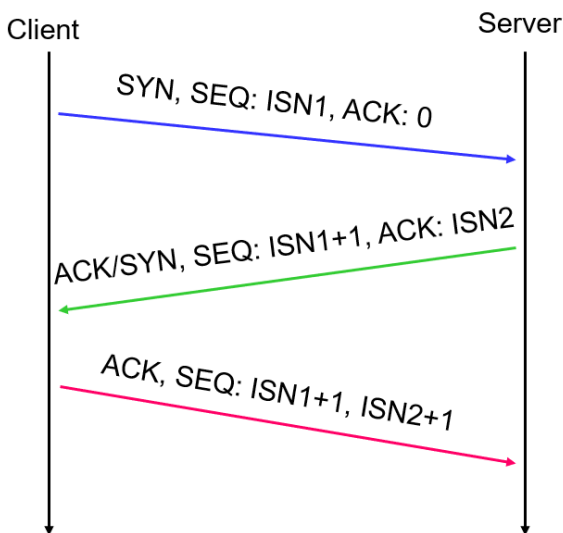


Figure 1 TCP connection



Figure 2 UDP connection

- **SYN:** The beginning of a connection
- **ACK:** Acknowledge receipt of a previous packet or transmission
- **ISN:** Initial sequence number

2. Required virtual machines

- Kali
- Metasploitable 2 or 3

3. Prerequisites

Get familiar with the following elements:

- TCP/IP protocol
- Port Scanning

The following options may be used to help you evade the firewall/IDS:

- **-f** (fragment packets):
 - This purpose of this option is to make it harder to detect the packets. By specifying this option once, Nmap will split the packet into 8 bytes or less after the IP header.
- **--mtu:**

LAB 11

- With this option, you can specify your own packet size fragmentation. The Maximum Transmission Unit (MTU) must be a multiple of eight or Nmap will give an error and exit.
- **-D (decoy):**
- By using this option, Nmap will send some of the probes from the spoofed IP addresses specified by the user. The idea is to mask the true IP address of the user in the logfiles. The user IP address is still in the logs. You can use RND to generate a random IP address or RND:number to generate the <number> IP address. The hosts you use for decoys should be up, or you will flood the target.
- Also remember that by using many decoys you can cause network congestion, so you may want to avoid that especially if you are scanning your client network.
- **--source-port <portnumber> or -g (spoof source port):** This option will be useful if the firewall is set up to allow all incoming traffic that comes from a specific port.
- **--data-length:**
- This option is used to change the default data length sent by Nmap in order to avoid being detected as Nmap scans.
- **--max-parallelism:** This option is usually set to one in order to instruct Nmap to send no more than one probe at a time to the target host.
- **--scan-delay <time>:** This option can be used to evade IDS/IPS that uses a threshold to detect port scanning activity.

4. Problems and questions

- I. Are the results obtained by nmap reliable?
- II. Does the information obtained about the target host depend from the scanning options?
- III. Is it permitted to use nmap to scan hosts without permission?

5. Tasks

- I. Run all VM you have installed in VirtualBOX,
Execute the following command:
***nmap 172.16.96.0/24* (WHAT IS THIS IP ADDRESS AND WHAT IS THE DIFFERENCE WITH THE ADDRESSES BELOW?)**
- II. Execute different types of TCP scans and compare results:
 - a. options -sT, -sS -sN, -sM, -sA, -sW, -sI)
 - b. describe the differences between scanning with aforementioned options
- III. Execute UDP scan

LAB 11

- IV. Try different nmap timing options (-T) from a set of values 0,1,2,3,4,5. What is the difference in results and performance?
- V. For selected system and selected service use service version detection (-sV) eg.
nmap -sV 172.16.96.x -p 22
- VI. Try to discover operating system version installed on VMs (option -O)
- VII. Check the directory /usr/share/nmap/scripts and find a few various nmap scripts and describe their application
 - a. Execute nmap -sC 172.16.96.x (change the IP address)
 - b. Execute nmap --script http-enum,http-headers,http-methods,http-phpversion
- VIII. Use Zenmap to discover the Virtual Network structure and VMs operating systems and active services
- IX. Use amap tool against selected VM and compare the results with those obtained during nmap scan
amap -bq 172.16.96.x 80 3306